



ISC 互联网安全大会



360 互联网安全中心

基于零信任的身份安全 理念、架构及实践

张泽洲 360企业安全身份安全产品负责人

张睿 360信息安全中心网络安全部负责人

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



ISC 互联网安全大会



360 互联网安全中心

基于零信任的身份安全

奇虎360集团零信任软件定义边界实践分享

张睿

360信息安全中心网络安全部负责人

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

1

360集团网络遇到的安全挑战

ZERO TRUST SECURITY

TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY

IDENTITY
AUTHENTICATION

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

我们网络安全运营现状



办公网

分支，端，Server

数据中心

IDC，骨干，隔离网络

移动网络

L2L，SSL，BYOD

云服务

公有云，私有云，云主机

安全基线策略

ACL变更管理

第三方、控股、外包？

流量监控

边界在哪？

终端EDR

服务器Agent

告警误报？

安全日志太多

审计溯源？

ZERO TRUST SECURITY

INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

不得不面对的安全挑战



ISC 互联网安全大会



360 互联网安全中心

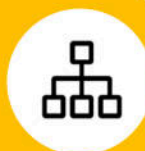
边界模糊
混合云+BYOD



Identity
设备可信



基础架构
难以改变



海量IDC资源
海量ACL



内网安全堪忧
大量第三方访问



业务弹性扩展
组织频繁变动

ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

“理想”与“现实”



ISC 互联网安全大会



360 互联网安全中心



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

我们意识到



ISC 互联网安全大会



360 互联网安全中心

墙破了!



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

2

谈谈“零信任”和“软件定义边界”

ZERO TRUST SECURITY

TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITYIDENTITY
AUTHENTICATION

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing · China

我们需要的“零信任”



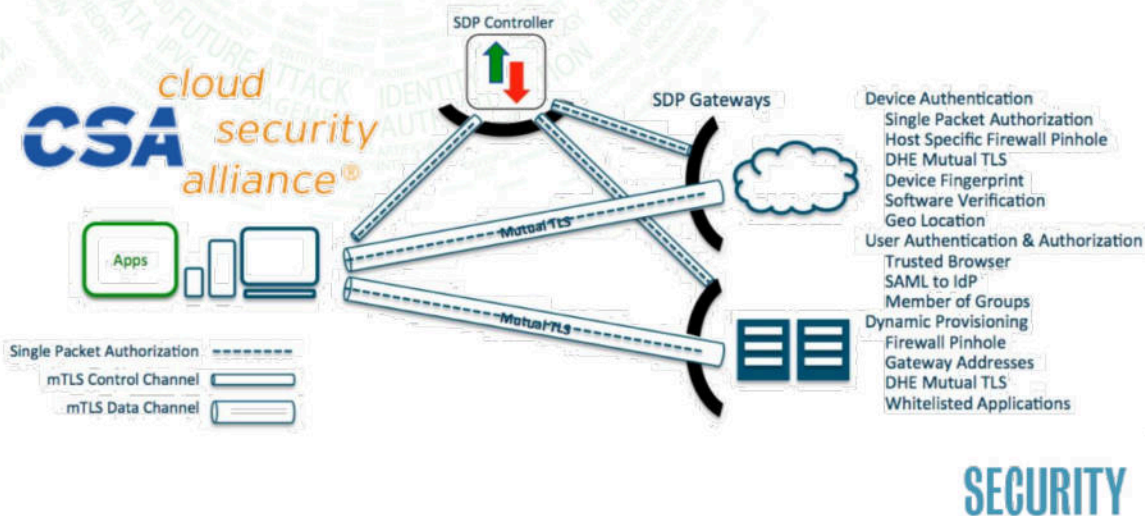
TRUST

- ! 不再“区分”内外网，基于安全状态访问控制
- ! 清晰可见的细粒度的访问控制策略 Need To Know
- ! 授权基于Know You and Your Device
- ! 访问所有资源必须认证、授权、加密
- ! 最小化的网络攻击面
- ! 所有网络访问流量必须监控和审计

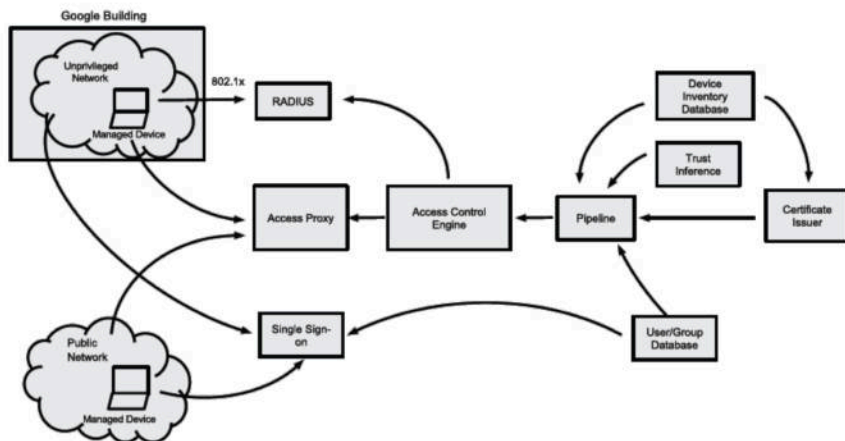
ZERO TRUST SECURITY

IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

软件定义边界（SDP）和BeyondCorp



BeyondCorp: A New Approach to Enterprise Security



ZERO TRUST SECURITY

核心组件共性：

控制器 - AC Engine+Pipe

网关 - AccessProxy

双重认证 - 账号+设备证书

加密隧道 - 双向TLS

SDP：软件定义动态、黑云SPA

BeyondCorp：大数据动态安全风控、
终端网络隔离 **C->G->S**



ISC 互联网安全大会



360 互联网安全中心

3

我们“零信任安全”的实践

ZERO TRUST SECURITY

IDENTITY SECURITY
PERSONAL PRIVACY

IDENTITY
AUTHENTICATION

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing · China

我们零信任SDP的初衷



ISC 互联网安全大会



360 互联网安全中心

边界清晰
统一接入

用户、设备
双重认证

清晰、高度自
动化的ACL

基于终端安全
状态动态授权

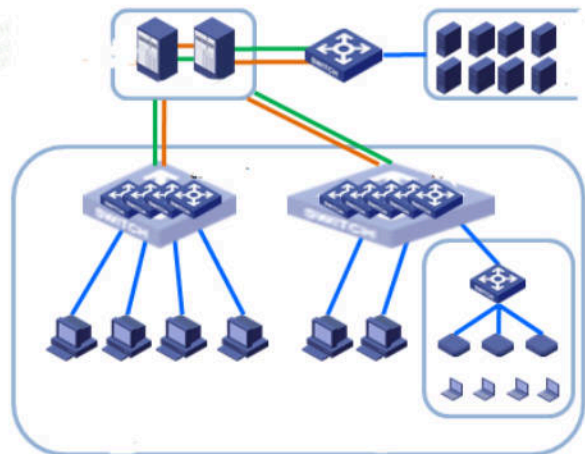
灵活、方便
扩展

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

零信任基础架构的演进

2016



大二层架构

DHCP与ID无关

SVI ACL 不灵活

ACL有限

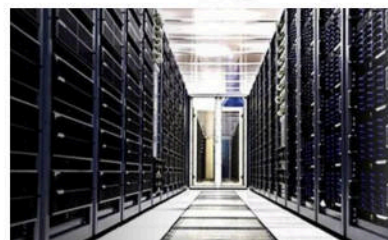
2017-2018



混合云



CORP
VLAN



IDC

ACL软件定义化

网络架构改造

2018

应用代理

SSO
Single Sign On

各种业务资源



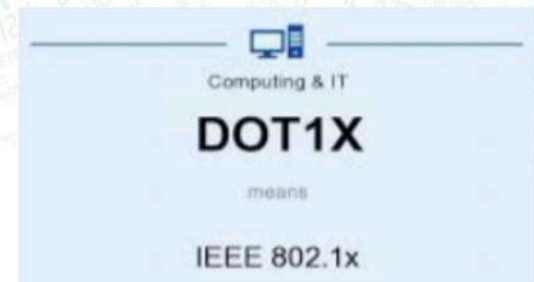
安全日志统一分析

平台自服务

逐核心应用迁移

ZERO TRUST SECURITY

我们的实践——身份源整合



ZERO TRUST SECURITY

SYSLOG

Identity Source

IP-address

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

严格的用户和终端管控



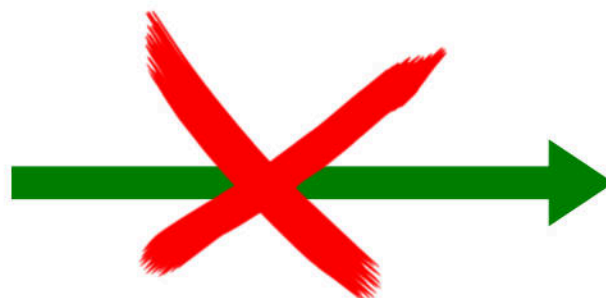
ISC 互联网安全大会



360 互联网安全中心



263404



ZERO TRUST SECURITY

INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

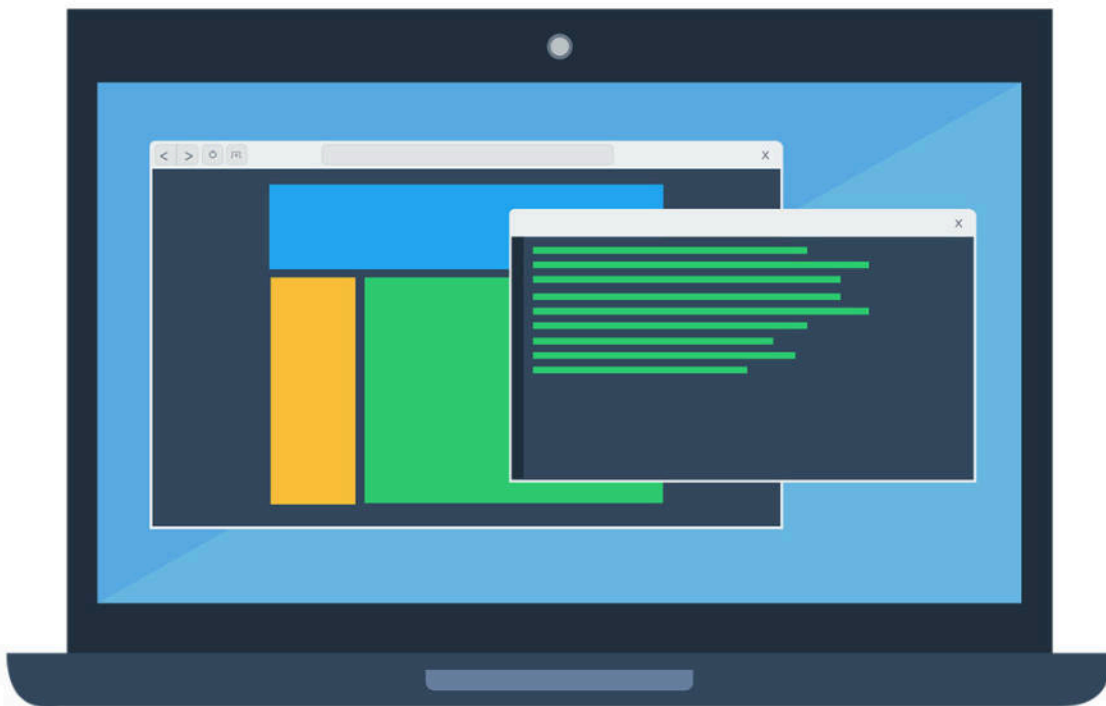
我们的SDP控制器



ISC 互联网安全大会



360 互联网安全中心



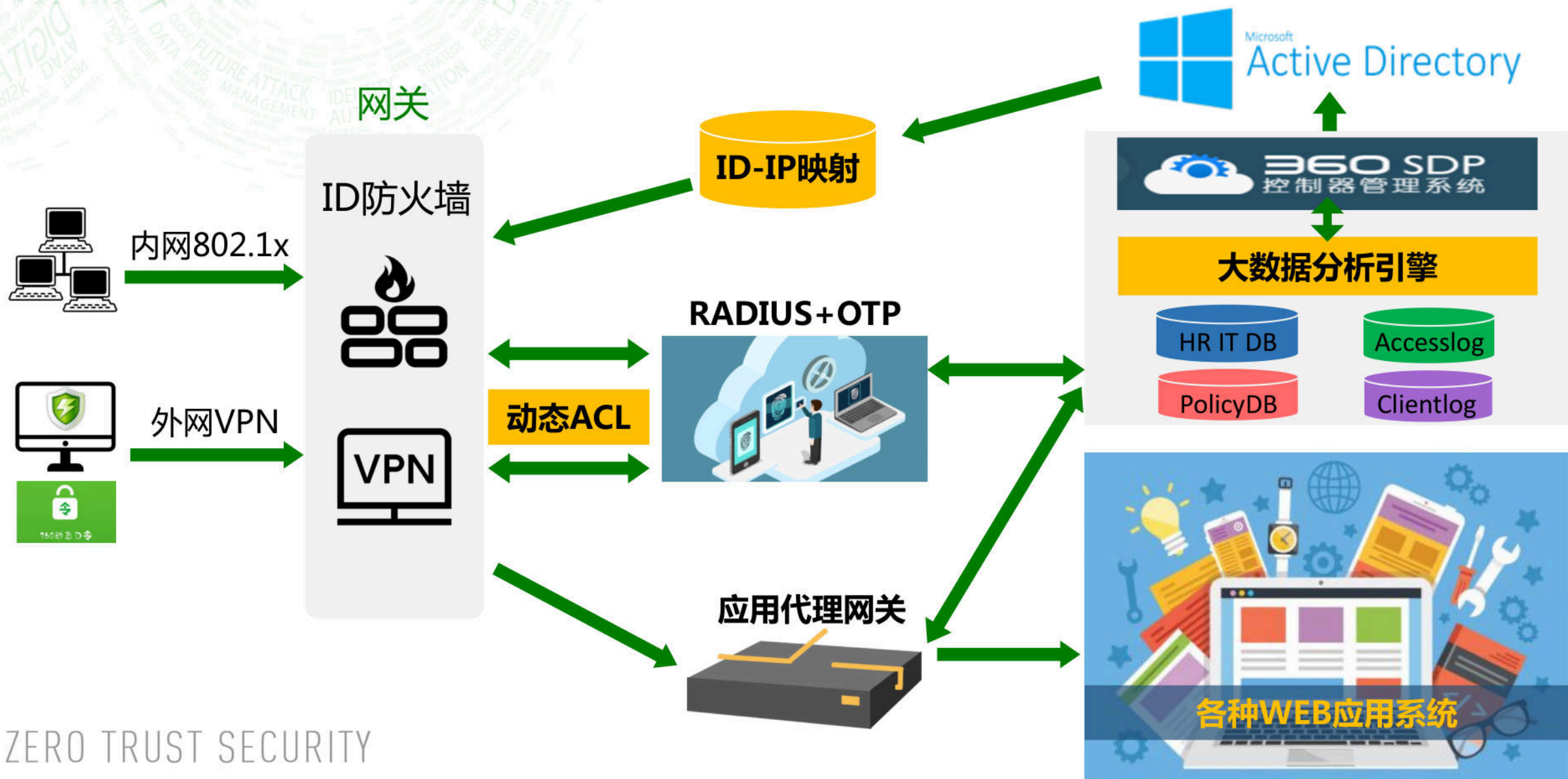
- 统一认证接入
- 软件定义
- 各种网关接入
- 关联数据分析
- 灵活授权

- ✓ ID身份
- ✓ 业务线
- ✓ 角色
- ✓ 项目组

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

不同网络访问场景的架构



如何迁移和授权



ISC 互联网安全大会



360 互联网安全中心

- ◆ 基于平台开放自服务，建立业务接口人
- ◆ 逐个业务线通知迁移新架构，做到影响小
- ◆ 分析我们的流量，评估后自动化生成ACL
- ◆ 业务线授权结合最小授权原则，自动化审批ACL



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing · China

集中管控后的流量监控和感知

- ◆分析网关和SSO 认证日志发现异常
- ◆全流量日志分析业务访问关系
- ◆Netflow和Count 评估和优化ACL
- ◆全流量DPI威胁检测、关联威胁情报、
终端日志和精细化资产标签感知威胁



ISC 互联网安全大会



360 互联网安全中心

基于零信任的身份安全 理念及通用架构

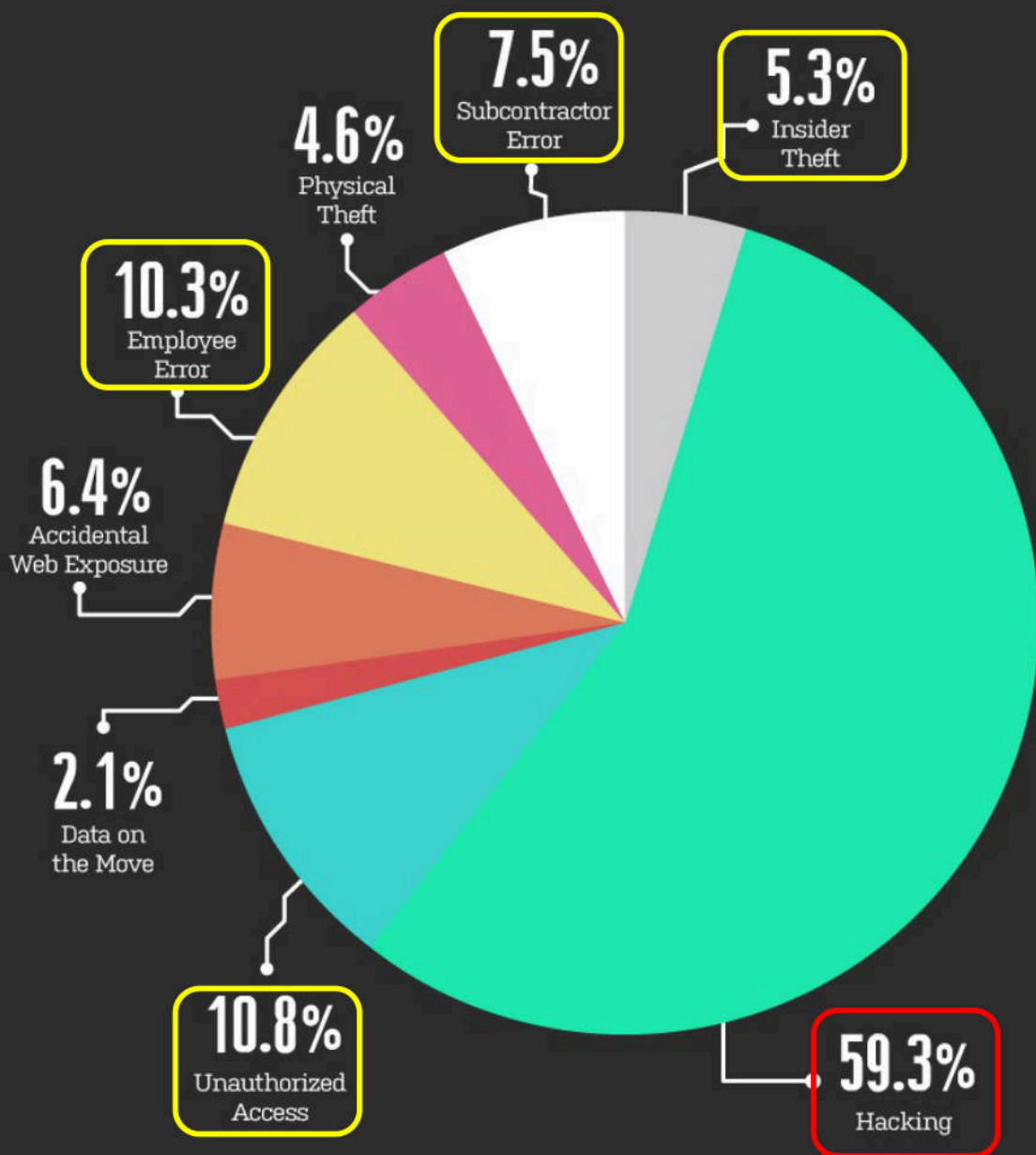
张泽洲

360企业安全身份安全产品负责人

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

CAUSES OF DATA BREACHES- 2017



数字化转型时代 业界的安全挑战



ISC 互联网安全大会



360 互联网安全中心

① 安全支出居高不下、数据泄露形式依旧严峻

Gartner预测，2018年全球安全支出**105,905,000,000\$**
2005~2018年，数据泄露记录数高达**1,066,247,507**

✓ 黑客仍然能轻易突破企业边界，是数据泄露第一大原因
81%的外部黑客攻击利用被盗口令或弱口令
黑客突破边界后，能在内网轻易横移

✓ 内部威胁，是数据泄露的第二大原因
内部威胁占比**33.9%**
内部窃贼、员工犯错、非授权访问、合作厂商犯错...

② 企业边界正在瓦解

BYOD、业务上云、外部协同

**基于边界的安全体系正在失效，
业界期待新的安全架构！**

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

业界早已开始行动，零信任安全架构广受认可



ZERO TRUST SECURITY

2010 : 提出

Forrester分析师John Kindervag提出零信任

2011~2017 : Google实践

Google成功完成 BeyondCorp项目，在超大型网络中率先实现零信任

NOW : 大幅推进

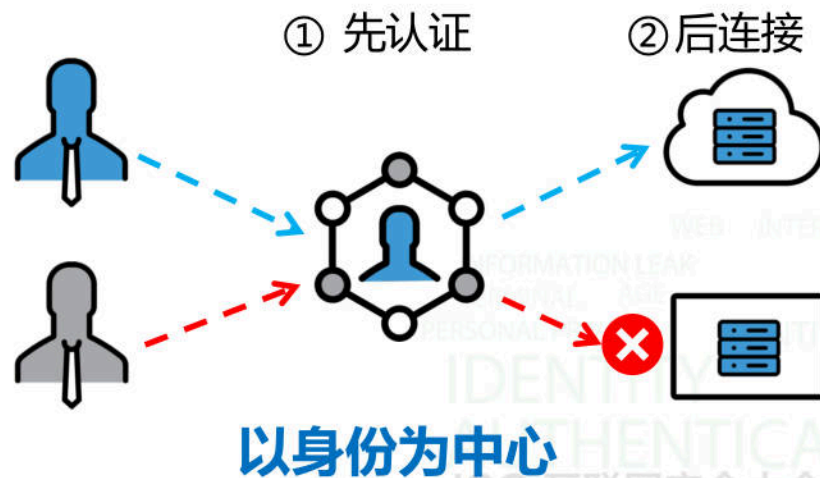
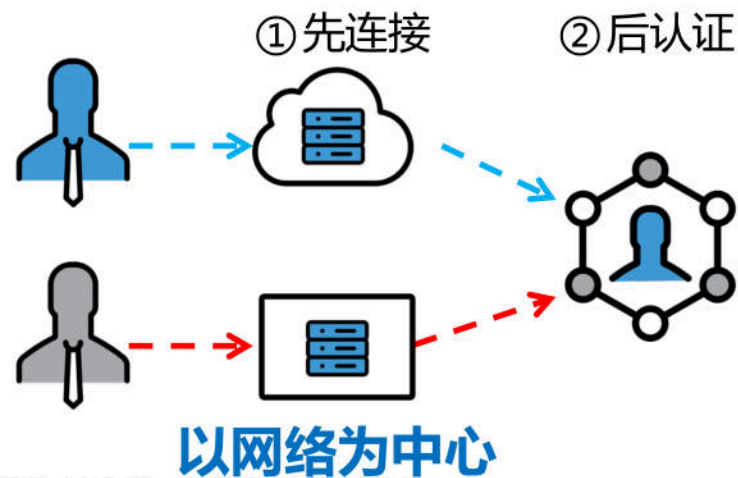
业界厂商大力跟进，包括 Cisco、微软、亚马逊、Cyxtera、Duo...

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

零信任安全的本质：以身份为中心进行访问控制



- ✓ **默认不信任**：应该始终假设网络充满威胁，每时每刻都存在外部和内部威胁，仅仅通过网络位置来评估信任是不够的。默认情况下不应该信任网络内部或外部的任何人/设备/系统。
- ✓ **基于身份和访问控制重构信任基础**，每个设备、用户、业务访问流都应该被认证、授权和加密。
- ✓ **访问控制策略应该是动态的**，基于多源的环境数据和风险评估计算出来。



零信任安全参考架构



以身份为中心

基于身份治理，构筑企业身份边界
基于用户-设备认证，重建信任



业务安全访问

业务隐藏于可信接入网关之后，只对合法用户/设备可见；可信接入网关即充当策略执行点，又承载流量加密能力。



动态访问控制

动态细粒度访问控制策略满足最小权限原则



智能身份分析

智能身份分析支撑动态访问和身份治理，提供智能、动态的高级特性。

ZERO TRUST SECURITY

关键实践1：设备认证确保设备可信



充分利用设备自带的TPM等硬件技术，确保设备可信。

灵活采用设备证书、设备指纹等软件技术，确保设备准确识别。

持续的终端风险监测和评估，确保设备持续安全可控。

关键实践2：用户认证确保用户可信



初始认证

初次登录系统需要认证。从易用性考虑，认证强度考虑最低安全要求即可。



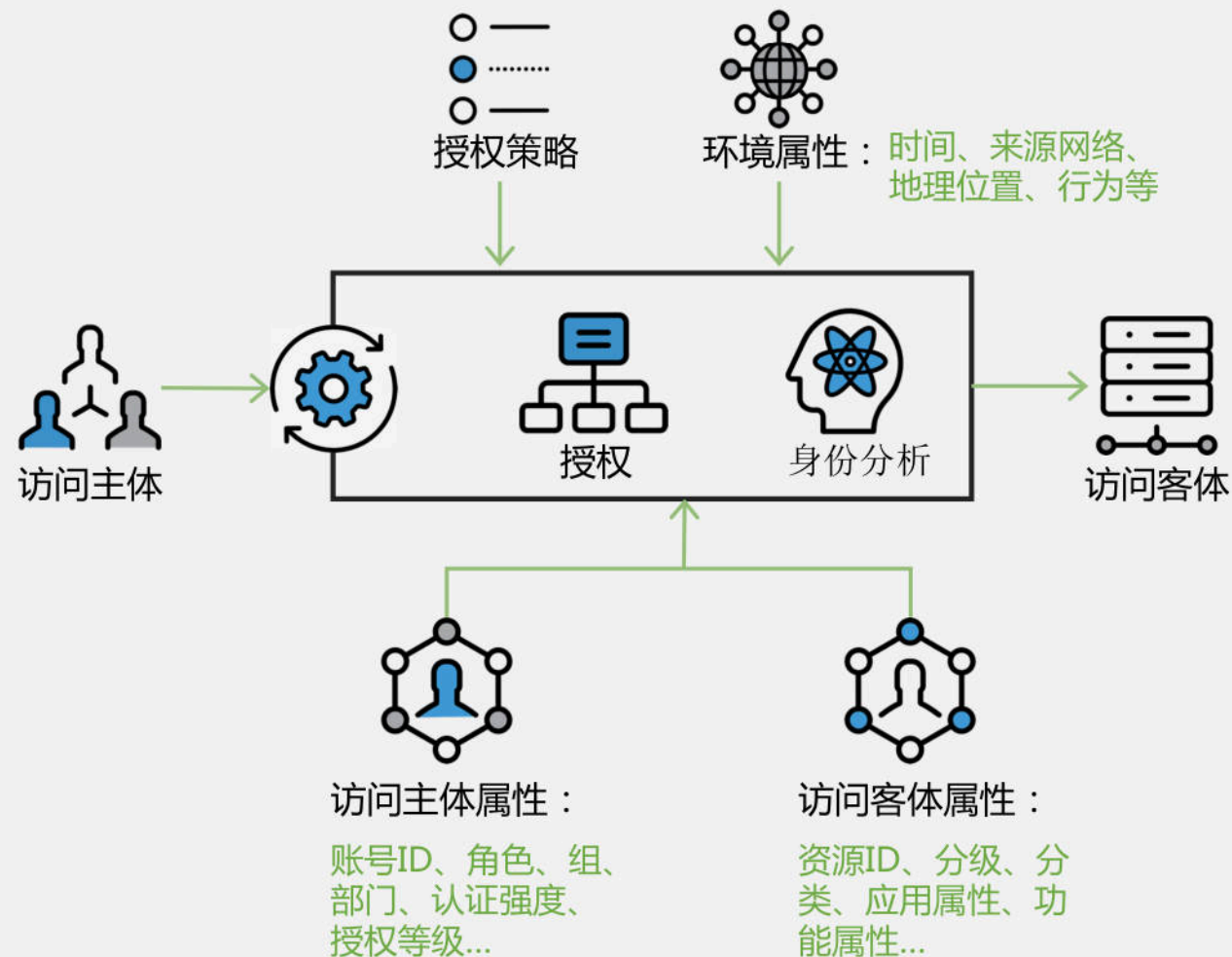
ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

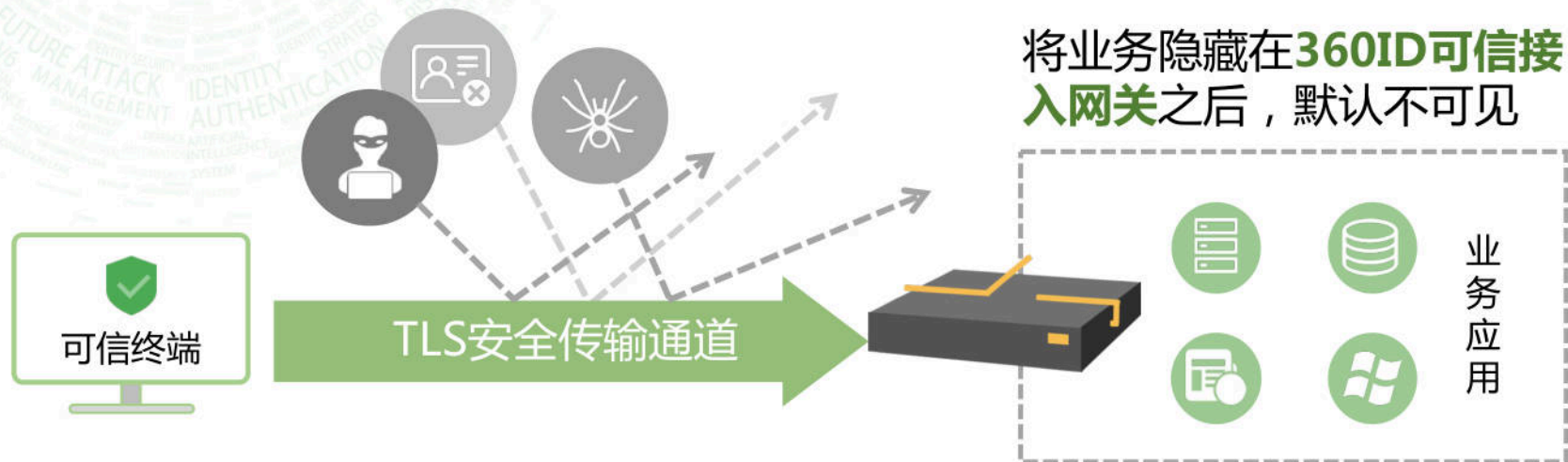
关键实践3：动态访问控制

可管理、易扩展、自适应

- RBAC：基于角色实现粗粒度授权，建立权限基线满足最小权限原则。
- ABAC：基于主体、客体和环境属性实现角色映射，满足细粒度授权需求，灵活管理。
- 基于风险评估和分析，实现角色过滤，提供场景和风险感知的动态授权



关键实践4：业务安全访问



传输加密

- 专业的TLS传输技术
- 支持国密算法套件
- 防中间人攻击

访问代理

- 业务默认隐藏，强制授权
- 令牌传递，实现单点登录
- 支持HTTP、RDP、SSH、Email...

全量日志

- 访问日志输出到身份分析平台进行风险评估
- 流量可视化

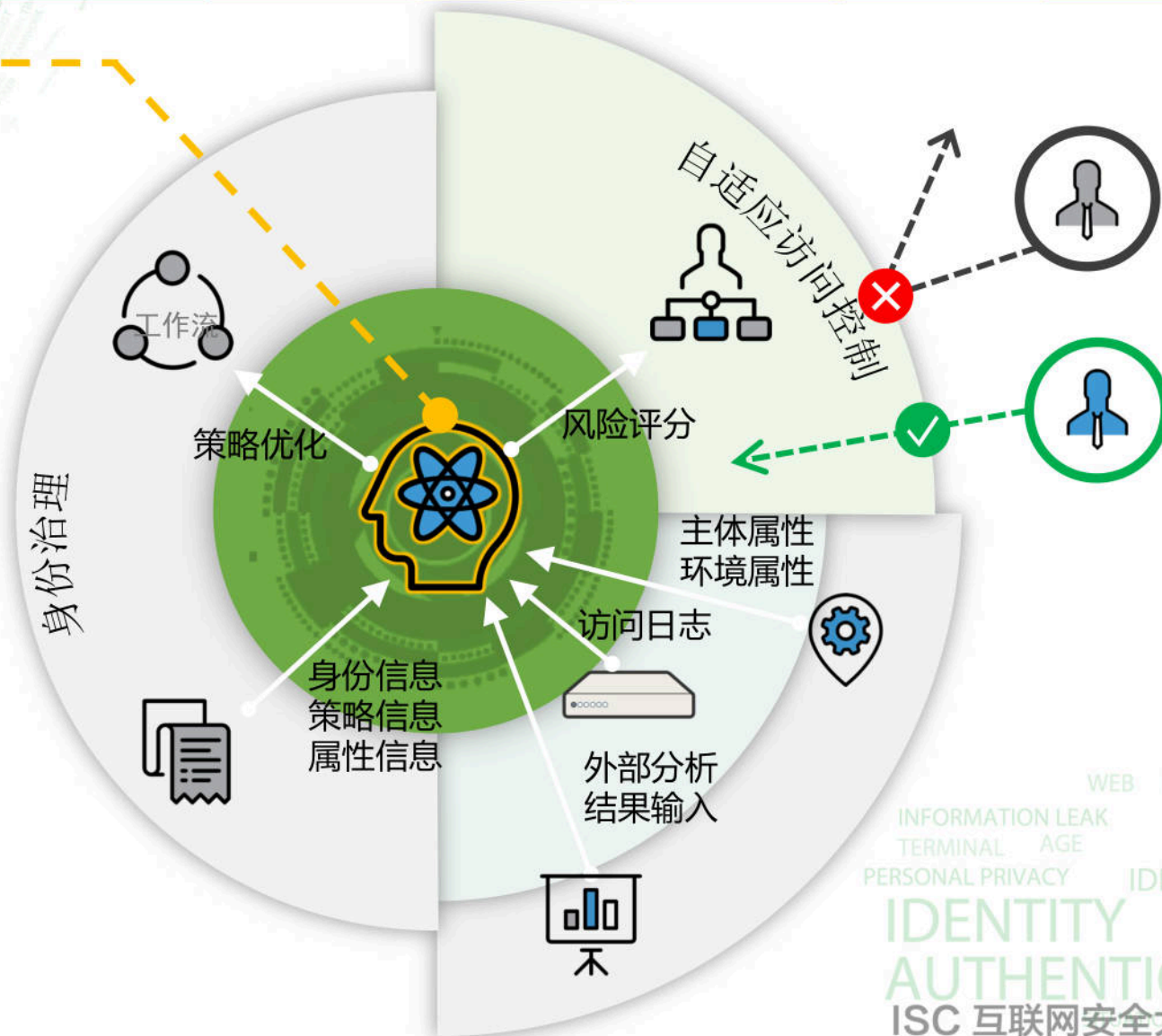
关键实践5：智能身份分析



ISC 互联网安全大会



360 互联网安全中心



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

传统身份管理

组织内部

封闭；集中式；扩展难

静态；定期变更

关闭大门

已知；独立功能

天，周，月

VS



访问管理



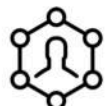
架构设计



授权策略



安全应对



风险管理



部署时间

现代身份管理

多组织；公众

开放；分布式；可扩展

动态；持续变更

分层设计

未知；融合功能

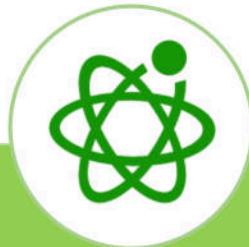
秒，时，天



无边界设计

信任的建立不能简单的基于网络位置

- 基于边界的防护，一旦边界突破就对攻击者敞开了大门。
- 网络边界正在消失（资源云化、远程访问、BYOD）
- 无边界----软件定义的边界
- 先认证、再连接



情景感知

访问权限取决于系统对用户和设备的了解

- 用户：自然权限、多因子认证、组织策略
- 设备：设备安全评估
- 环境：位置、时间、网络、风险级别



动态访问控制

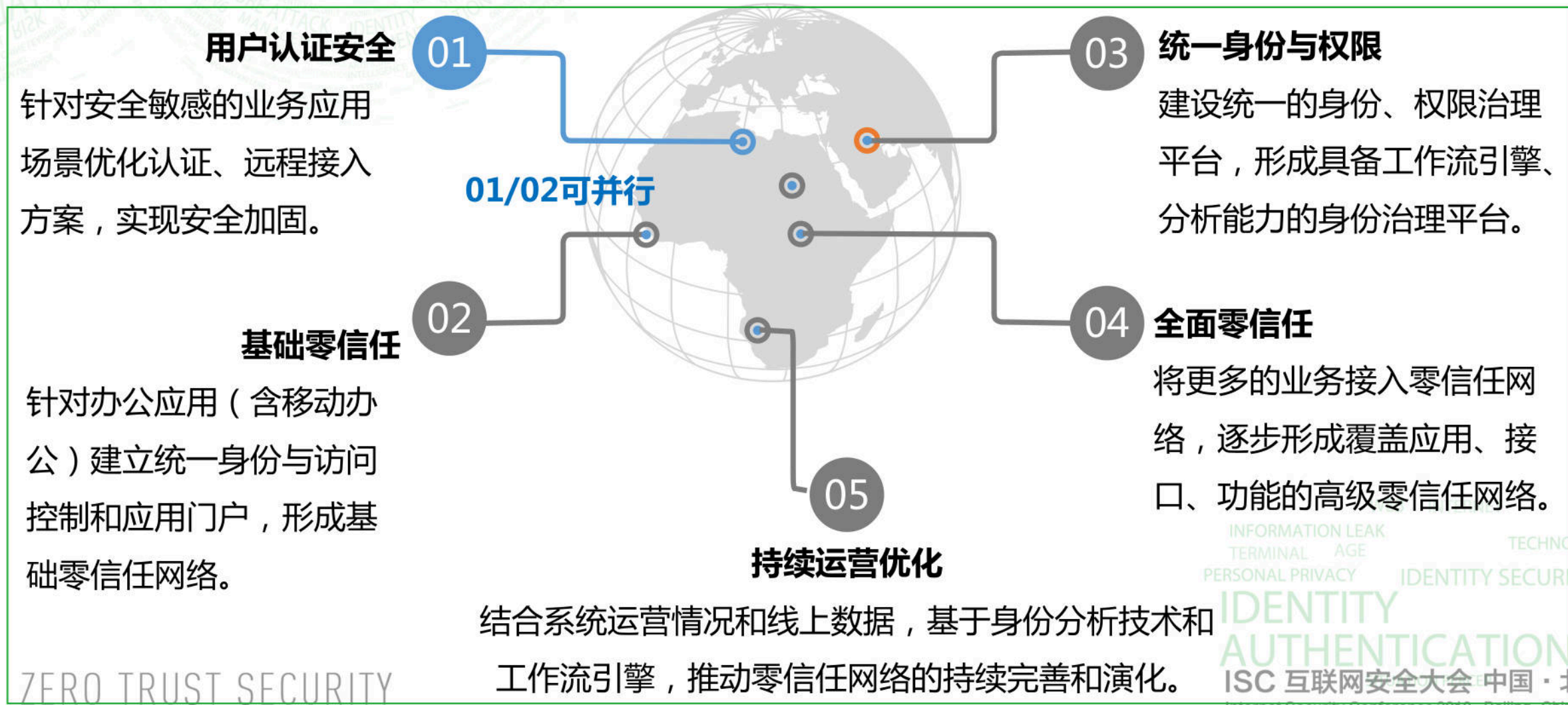
基于多维属性产生动态ACL，所有访问都必须被认证、授权和加密

- 用户只能看到授权访问的资源
- 基于情景和风险因子自适应访问
- 基于持续情景变化更新访问控制策略

零信任架构是系统工程，不可能一蹴而就



高层领导驱动、安全规划先行、新建业务优先、方案选型开放



360ID TrustAccess身份安全解决方案



ISC 互联网安全大会



360 互联网安全中心



新身份 新边界

ZERO TRUST SECURITY



value 1

基于零信任，推动企业安全重构



value 2

敏捷、智能、安全的现代身份管理平台



value 3

适应现代IT环境，助力企业数字化转型

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China